

Privacy

La disciplina giuridica della protezione dei dati personali

Corso “Diritto dell’informatica T”

a.a. 2025/2026

Claudia Cevenini

Norme di riferimento

Regolamento Generale sulla protezione dei dati (Reg. UE 2016/679) o GDPR (General Data Protection Regulation)

In vigore dal 25 maggio 2016

Si **applica direttamente** in tutti gli Stati Membri della UE dal **25 maggio 2018**

Margine di autonomia agli Stati Membri su determinati ambiti.

Codice privacy (D.Lgs. 196/03) è stato aggiornato a settembre 2018 per adeguarlo al Regolamento.

Cosa tutela il Regolamento?

Il regolamento **protegge** i **diritti** e le **libertà fondamentali** delle **persone fisiche**, in particolare il **diritto alla protezione dei dati personali**.

Diritto alla **protezione** dei **dati personali** deve essere garantito a **chiunque**.

Il GDPR si applica ai trattamenti di dati personali delle **persone fisiche** (=individui) e **NON** delle persone giuridiche (= società, enti e associazioni).

NON si applica ai **dati anonimi**, da cui sia impossibile identificare una persona.

Ambito di applicazione materiale

Il Regolamento **si applica** al trattamento di dati personali:

- interamente o parzialmente **automatizzato** e
- **non automatizzato** di dati personali contenuti in un archivio o destinati a figurarvi

Il regolamento **non si applica** al trattamento di dati personali:

- effettuato da **persone fisiche** per l'esercizio di **attività esclusivamente personali o domestiche**
- effettuato dalle **autorità competenti** a fini di prevenzione, indagine, accertamento o perseguimento di **reati** o esecuzione di **sanzioni penali**, salvaguardia contro minacce alla **sicurezza pubblica** e la prevenzione delle stesse.

Ambito di applicazione territoriale

Il Regolamento si applica al trattamento di dati personali:

effettuato da **titolare o responsabile stabilito** nell'UE, indipendentemente dal luogo di trattamento dei dati

effettuato da **titolare o responsabile non stabilito nell'UE**, se riguarda **dati di interessati** che **si trovano nell'UE**:

- per l'**offerta di beni o la prestazione di servizi** o
- per **monitorare il loro comportamento** all'interno dell'UE.

Il concetto di dato personale

Qualsiasi informazione riguardante una **persona fisica identificata o identificabile** (=interessato); si considera identificabile la persona fisica che può essere identificata, **direttamente o indirettamente**, con particolare riferimento a un identificativo come il nome, un numero di identificazione, dati relativi all'ubicazione, un identificativo online o a uno o più elementi caratteristici della sua identità fisica, fisiologica, genetica, psichica, economica, culturale o sociale

IMPORTANTE!!

I dati personali si distinguono in “comuni” e “sensibili” (= altre categorie di dati).

Il concetto di trattamento

Qualsiasi operazione o insieme di operazioni, compiute con o senza l'ausilio di processi automatizzati e applicate a dati personali o insiemi di dati personali, come:

- raccolta,
- registrazione,
- organizzazione,
- strutturazione,
- conservazione,
- adattamento o modifica,
- estrazione,
- consultazione,
- uso,
- comunicazione mediante trasmissione,
- diffusione o qualsiasi altra forma di messa a disposizione,
- raffronto o interconnessione,
- limitazione,
- cancellazione o distruzione.

Alcune attività specifiche di trattamento

Profilazione: qualsiasi forma di trattamento automatizzato di dati personali consistente nell'utilizzo di tali dati personali per valutare determinati aspetti personali relativi a una persona fisica, in particolare per analizzare o prevedere aspetti riguardanti il rendimento professionale, la situazione economica, la salute, le preferenze personali, gli interessi, l'affidabilità, il comportamento, l'ubicazione o gli spostamenti di detta persona fisica.

Pseudonimizzazione: il trattamento dei dati personali in modo tale che i dati personali non possano più essere attribuiti a un interessato specifico senza l'utilizzo di informazioni aggiuntive, a condizione che tali informazioni aggiuntive siano conservate separatamente e soggette a misure tecniche e organizzative intese a garantire che tali dati personali non siano attribuiti a una persona fisica identificata o identificabile.

I soggetti coinvolti nel trattamento

TITOLARE

La **persona fisica o giuridica, l'autorità pubblica, il servizio o altro organismo** che, singolarmente o insieme ad altri, **determina le finalità e i mezzi del trattamento** di dati personali; quando le finalità e i mezzi di tale trattamento sono determinati dal diritto dell'Unione o degli Stati membri, il titolare del trattamento o i criteri specifici applicabili alla sua designazione possono essere stabiliti dal diritto dell'Unione o degli Stati membri.

[NOTA: Il T. tratta dati per PROPRIO conto, *es. una società che tratta i dati dei propri clienti e dipendenti*]

Obblighi del titolare 1/4

PROTEZIONE DEI DATI FIN DALLA PROGETTAZIONE

COSA DEVE FARE:

Il **titolare** del trattamento deve mettere in atto **misure TECNICHE e ORGANIZZATIVE adeguate**, quali la **pseudonimizzazione**.

PERCHÉ' LO DEVE FARE:

Le misure hanno lo scopo di:

- attuare in modo efficace i principi di **protezione dei dati**, quali la **minimizzazione**, e
- integrare nel trattamento le necessarie **garanzie** al fine di soddisfare i **requisiti** del **Regolamento** e **tutelare i diritti** degli **interessati**.

Obblighi del titolare 2/4

QUANDO LO DEVE FARE:

- sia **al momento di determinare i mezzi del trattamento,**
- sia **all'atto del trattamento stesso.**

(Obbligo indicato anche come *data protection by design* o *privacy by design*)

STUDIARE ART. 25 DEL REGOLAMENTO

Obblighi del titolare 3/4

PROTEZIONE DEI DATI PER IMPOSTAZIONE PREDEFINITA

Il **titolare** del trattamento deve mettere in atto **misure TECNICHE e ORGANIZZATIVE adeguate** per garantire che siano **trattati**, per **impostazione predefinita**, **solo i dati personali necessari** per ogni specifica **finalità** del trattamento.

Tale obbligo vale per

- la **quantità** dei dati personali raccolti,
- la **portata** del trattamento,
- il **periodo** di conservazione e
- **l'accessibilità**.

Obblighi del titolare 4/4

In particolare, dette misure garantiscono che, **per impostazione predefinita, non** siano resi **accessibili dati** personali a un **numero indefinito** di **persone** fisiche senza l'intervento della persona fisica.

(Obbligo indicato anche come *data protection by default o privacy by default*)

STUDIARE ART. 25 DEL REGOLAMENTO

I soggetti coinvolti nel trattamento

RESPONSABILE

La persona fisica o giuridica, l'autorità pubblica, il servizio o altro organismo che tratta dati personali per conto del titolare del trattamento.

[Es. consulente del lavoro che tratta dati dei dipendenti delle società per cui elabora le buste paga, call center che contatta i clienti dei propri committenti, fornitore di servizi cloud che tratta dati per conto dei propri clienti]

INTERESSATO

Persona fisica cui si riferiscono i dati personali.

[es. utente, cliente, paziente]

Responsabile del trattamento

Deve fornire **garanzie sufficienti** per mettere in atto **misure tecniche e organizzative adeguate**.

Può nominare a sua volta un **sub-responsabile solo** con **autorizzazione** scritta, specifica o generale, del **titolare**.

Il Responsabile deve trattare i dati personali soltanto su **istruzione documentata** del **titolare** del trattamento.

ATTENZIONE!!!

Non confondete il “Responsabile del trattamento” (= *data processor*) con il “Responsabile della protezione dei dati” (*Data Protection Officer*)!!

Come è nominato il Responsabile del trattamento?

Occorre un **contratto** o altro atto giuridico che vincoli il responsabile al titolare e che stipuli

- la **materia** disciplinata,
- la **durata** del trattamento,
- la **natura** del trattamento,
- la **finalità** del trattamento,
- il **tipo** di **dati** personali,
- le **categorie** di **interessati**,
- gli **obblighi** e i **diritti** del **titolare** del trattamento.

ATTENZIONE a non confondere il contratto di servizi (o incarico/mandato professionale o termini e condizioni di servizio, ecc.) e il contratto per il trattamento dei dati personali (questo).

I soggetti coinvolti nel trattamento

SOGGETTO AUTORIZZATO/DESIGNATO

Collaboratore o dipendente del Titolare o del Responsabile.

1. Il **titolare** o il **responsabile** del trattamento possono prevedere, sotto la propria responsabilità e **nell'ambito del proprio assetto organizzativo**, che specifici compiti e funzioni connessi al trattamento di dati personali siano attribuiti a **persone fisiche, espressamente designate, che operano sotto la loro autorità**.

2. **Il titolare o il responsabile del trattamento individuano le modalità più opportune per autorizzare** al trattamento dei dati personali le persone che operano sotto la propria autorità diretta.

V. Codice Privacy, art. 2-quaterdecies (Attribuzione di funzioni e compiti a soggetti designati)

Principi applicabili al trattamento di dati personali 1/3

I dati personali devono essere:

- trattati in modo lecito, corretto e trasparente nei confronti dell'interessato («**liceità, correttezza e trasparenza**»);
- raccolti per finalità determinate, esplicite e legittime, e successivamente trattati in modo che non sia incompatibile con tali finalità; un ulteriore trattamento dei dati personali a fini di archiviazione nel pubblico interesse, di ricerca scientifica o storica o a fini statistici non è considerato incompatibile con le finalità iniziali («**limitazione della finalità**»);
- adeguati, pertinenti e limitati a quanto necessario rispetto alle finalità per le quali sono trattati («**minimizzazione dei dati**»);

Principi applicabili al trattamento di dati personali 2/3

- esatti e, se necessario, aggiornati; devono essere adottate tutte le misure ragionevoli per cancellare o rettificare tempestivamente i dati inesatti rispetto alle finalità per le quali sono trattati («**esattezza**»);
- conservati in una forma che consenta l'identificazione degli interessati per un arco di tempo non superiore al conseguimento delle finalità per le quali sono trattati; i dati personali possono essere conservati per periodi più lunghi a condizione che siano trattati esclusivamente a fini di archiviazione nel pubblico interesse, di ricerca scientifica o storica o a fini statistici («**limitazione della conservazione**»);

Principi applicabili al trattamento di dati personali 3/3

- trattati in maniera da garantire un'adeguata sicurezza dei dati personali, compresa la protezione, mediante misure tecniche e organizzative adeguate, da trattamenti non autorizzati o illeciti e dalla perdita, dalla distruzione o dal danno accidentali («**integrità e riservatezza**»).

Il titolare del trattamento è competente per il rispetto di questi principi e deve essere in grado di **comprovarlo, dimostrarlo** («**responsabilizzazione**»).

Liceità del trattamento 1/2

Il trattamento è **lecito solo se** e nella misura in cui ricorre **almeno una delle seguenti condizioni (basi giuridiche del trattamento)**:

- l'interessato ha espresso il **consenso** al trattamento dei propri dati personali per una o più specifiche finalità;
- il trattamento è **necessario all'esecuzione** di un **contratto** di cui l'interessato è parte o all'esecuzione di **misure precontrattuali** adottate su richiesta dello stesso;
- il trattamento è **necessario per adempiere un obbligo legale** al quale è soggetto il titolare del trattamento;
- il trattamento è **necessario** per la **salvaguardia** degli **interessi vitali** dell'interessato o di un'altra persona fisica;

Liceità del trattamento 2/2

- il trattamento è necessario per l'esecuzione di un **compito di interesse pubblico o connesso all'esercizio di pubblici poteri** di cui è investito il **titolare** del trattamento;
- il trattamento è **necessario** per il perseguimento del **legittimo interesse** del **titolare** del trattamento o di terzi, a condizione che non prevalgano gli interessi o i diritti e le libertà fondamentali dell'interessato che richiedono la protezione dei dati personali, in particolare se l'interessato è un minore.

[la regola 6 non si applica al trattamento di dati effettuato dalle autorità pubbliche nell'esecuzione dei loro compiti]

Condizioni per il consenso 1/2

Se il trattamento è basato sul consenso, il **titolare** del trattamento deve essere in grado di **dimostrare** che l'interessato ha prestato il proprio **consenso** al trattamento dei propri dati personali.

Se il consenso dell'interessato è prestato **nel contesto di una dichiarazione scritta che riguarda anche altre questioni**, la richiesta di consenso è presentata in modo

- **chiaramente distinguibile** dalle altre materie,
- in forma **comprensibile** e
- **facilmente accessibile**,
- utilizzando un **linguaggio semplice e chiaro**.

Nessuna parte di una tale dichiarazione che costituisca una violazione del Regolamento è vincolante.

Condizioni per il consenso 2/2

L'interessato ha il **diritto di revocare** il proprio **consenso** in **qualsiasi momento**.

La revoca del consenso **non pregiudica la liceità del trattamento basata sul consenso prima della revoca**. Prima di esprimere il proprio consenso, l'interessato è informato di ciò.

Il consenso è **revocato con la stessa facilità con cui è accordato**.

Nel valutare se il consenso sia stato liberamente prestato, si tiene nella massima considerazione l'eventualità, tra le altre, che **l'esecuzione di un contratto**, compresa la **prestazione di un servizio**, sia **condizionata** alla prestazione del **consenso** al trattamento di dati personali **non necessario** all'esecuzione di tale contratto.

Consenso dei minori

Per l'offerta diretta di servizi della società dell'informazione ai minori, il trattamento di dati personali del minore è lecito ove il minore abbia **almeno 16 anni**.

Ove il minore abbia un'età **inferiore ai 16 anni**, tale trattamento è lecito soltanto se e nella misura in cui tale **consenso** è prestato o autorizzato dal **titolare** della **responsabilità genitoriale**.

Gli **Stati membri** possono stabilire per legge un'età **inferiore** a tali fini purché **non inferiore ai 13 anni**. Per l'Italia è di 14 anni (art. 2-*quinquies* Codice Privacy).

Il titolare del trattamento si adopera in ogni modo ragionevole per verificare in tali casi che il consenso sia prestato o autorizzato dal titolare della responsabilità genitoriale sul minore, in considerazione delle tecnologie disponibili.

[Esempio: Whatsapp vietò l'uso dell'app ai minori di 16 anni senza autorizzazione dei genitori.]

Trattamento di categorie particolari di dati personali 1/5

È **vietato** trattare dati personali che rivelino

- l'**origine razziale o etnica**,
- le **opinioni politiche**,
- le **convinzioni religiose o filosofiche**,
- l'**appartenenza sindacale**,
- dati **genetici**,
- dati **biometrici** intesi a identificare in modo univoco una persona fisica,
- dati relativi alla **salute**,
- dati relativi alla **vita sessuale** o all'**orientamento sessuale** della persona.

Si tratta dei dati comunemente denominati "**sensibili**".

Trattamento di categorie particolari di dati personali 2/5

Questa regola non vale nei seguenti casi (= i dati appartenenti a categorie particolari possono essere trattati in presenza delle seguenti condizioni):

- A. l'interessato ha prestato il proprio **consenso esplicito** al trattamento di tali dati personali per una o più **finalità specifiche**;
- B. il trattamento è **necessario** per assolvere gli **obblighi** ed esercitare i **diritti** specifici del **titolare** del trattamento o dell'**interessato** in materia di **diritto del lavoro** e della **sicurezza sociale** e **protezione sociale**, nella misura in cui sia autorizzato dal **diritto** dell'Unione o degli Stati membri o da un **contratto collettivo** ai sensi del diritto degli Stati membri, in presenza di garanzie appropriate per i diritti fondamentali e gli interessi dell'interessato;

Trattamento di categorie particolari di dati personali 3/5

- C. il trattamento è **necessario** per tutelare un **interesse vitale** dell'interessato o di un'altra persona fisica qualora l'interessato si trovi nell'**incapacità fisica o giuridica** di prestare il proprio **consenso**;
- D. il trattamento è effettuato, nell'ambito delle sue legittime attività e con adeguate garanzie, da una **fondazione, associazione** o altro organismo **senza scopo di lucro** che persegua finalità politiche, filosofiche, religiose o sindacali, a condizione che il trattamento riguardi unicamente i membri, gli ex membri o le persone che hanno regolari contatti con la fondazione, l'associazione o l'organismo a motivo delle sue finalità e che i dati personali non siano comunicati all'esterno senza il consenso dell'interessato;
- E. il trattamento riguarda **dati personali resi manifestamente pubblici dall'interessato**;

Trattamento di categorie particolari di dati personali 4/5

- F. il trattamento è **necessario** per **accertare, esercitare o difendere** un **diritto in sede giudiziaria** o ogniqualvolta le **autorità giurisdizionali** esercitino le loro **funzioni giurisdizionali**;
- G. il trattamento è necessario per motivi di **interesse pubblico rilevante** sulla base del diritto UE o nazionale;
- H. il trattamento è **necessario** per finalità di **medicina preventiva** o di **medicina del lavoro, valutazione della capacità lavorativa del dipendente, diagnosi, assistenza o terapia sanitaria o sociale** ovvero gestione dei **sistemi e servizi sanitari o sociali** sulla base del diritto UE o nazionale o conformemente al contratto con un **professionista** della **sanità**;

Trattamento di categorie particolari di dati personali 5/5

- I. il trattamento è **necessario** per motivi di **interesse pubblico** nel settore della **sanità pubblica**, quali la protezione da gravi minacce per la salute a carattere transfrontaliero o la garanzia di parametri elevati di qualità e sicurezza dell'assistenza sanitaria e dei medicinali e dei dispositivi medici, sulla base del diritto UE o nazionale;
- J. il trattamento è **necessario** a fini di **archiviazione** nel **pubblico interesse**, di **ricerca scientifica** o **storica** o a fini **statistici** in base al diritto UE o nazionale.

Gli **Stati membri** possono mantenere o introdurre **ulteriori condizioni**, comprese **limitazioni**, con riguardo al trattamento di dati **genetici**, dati **biometrici** o dati relativi alla **salute**.

Informativa 1/2

PRIMA di raccogliere i dati deve essere fornita un'informativa con un contenuto minimo (casi principali, leggete gli artt. 12, 13 e 14 del Regolamento):

- l'identità e i dati di contatto del **titolare** del trattamento,
- i dati di contatto del responsabile della protezione dei dati (**DPO** o **RPD**) se è stato nominato
- le **finalità** del trattamento e la **base giuridica** del trattamento
- eventuali **destinatari** o eventuali **categorie** di destinatari dei dati personali
- l'**intenzione** del titolare del trattamento di trasferire dati personali a un **paese terzo** o a un'organizzazione internazionale
- il **periodo di conservazione** dei dati personali o, se non è possibile, i **criteri** utilizzati per determinare tale periodo

Informativa 2/2

- **diritti** dell'**interessato** (es. accesso ai dati, rettifica, cancellazione, limitazione, opposizione, portabilità)
- diritto di **revocare** il consenso in qualsiasi momento senza pregiudicare la liceità del trattamento basata sul consenso prestato prima della revoca
- diritto di proporre **reclamo** a un'autorità di controllo
- se la **comunicazione** di dati personali è un **obbligo legale o contrattuale** oppure un **requisito necessario** per la conclusione di un contratto, e se l'interessato ha l'obbligo di fornire i dati personali nonché le possibili conseguenze della mancata comunicazione di tali dati
- l'esistenza di un **processo decisionale automatizzato**, compresa la **profilazione**.

Diritti dell'interessato

- Diritto di **accesso**
- Diritto di **rettifica**
- Diritto di **integrazione**
- Diritto di **cancellazione** (c.d. diritto all'oblio)
- Diritto di **limitazione** del trattamento
- Diritto alla **portabilità** dei dati
- Diritto di **opposizione**

Leggere attentamente gli artt. da 15 a 22 del Regolamento.

Registri delle attività di trattamento

Chi deve tenerli?

Tutte le imprese od organizzazioni con più di 250 dipendenti.

Le imprese od organizzazioni con **meno di 250 dipendenti** **se**:

- il trattamento che esse effettuano possa presentare un **rischio** per i **diritti e le libertà dell'interessato**,
- il **trattamento non** sia **occasionale o**
- includa il trattamento di **categorie particolari di dati**.

Come vanno tenuti?

In **forma scritta**, anche in **formato elettronico**.

Devono essere messi a disposizione in caso di controllo.

Contenuti dei Registri 1/2

Registro del Titolare

- nome e dati di contatto del **titolare** del trattamento e del responsabile della protezione dei dati (**DPO**)
- **finalità** del trattamento
- descrizione delle **categorie di interessati** e delle **categorie di dati personali**
- **categorie di destinatari**
- **trasferimenti** di dati personali verso un **paese terzo** o un'organizzazione internazionale
- ove possibile, i **termini ultimi** previsti per la **cancellazione** delle **diverse categorie di dati**
- ove possibile, una **descrizione generale** delle **misure di sicurezza tecniche e organizzative**.

Contenuti dei Registri 2/2

Registro del Responsabile

- **nome e dati di contatto** del responsabile o dei responsabili del trattamento, di **ogni titolare per conto del quale agisce** il responsabile del trattamento, ove applicabile, del responsabile della protezione dei dati (**DPO**);
- **categorie** dei **trattamenti** effettuati per conto di ogni titolare
- ove applicabile, i **trasferimenti** di dati personali verso un paese **terzo** o un'organizzazione internazionale, compresa
- l'**identificazione** del **paese terzo** o dell'organizzazione internazionale
- **descrizione** generale delle **misure di sicurezza tecniche e organizzative**.

Misure di sicurezza – Titolare 1/2

Tenuto conto di:

- **natura,**
- **ambito di applicazione,**
- **contesto e**
- **finalità** del trattamento,
- **rischi** aventi probabilità e gravità diverse per i diritti e le libertà delle persone fisiche,

il **Titolare** del trattamento deve attuare **misure tecniche e organizzative adeguate** per

- **garantire,** ed
- essere in grado di **dimostrare,**

che il **trattamento** è effettuato **conformemente al Regolamento.**

Le **misure** sono **riesaminate** e **aggiornate** se necessario.

Misure di sicurezza – Titolare 2/2

Se ciò è proporzionato rispetto alle attività di trattamento, le misure includono l'**attuazione di politiche adeguate** in materia di protezione dei dati da parte del **titolare** del trattamento.

L'adesione a **codici di condotta** o a un **meccanismo di certificazione** può essere utilizzata come elemento per dimostrare il rispetto degli obblighi del titolare del trattamento.

STUDIARE ART. 24 DEL REGOLAMENTO

Misure di sicurezza – cosa fare

Nel valutare l'adeguato livello di sicurezza, si **tiene conto** in special modo dei **rischi** presentati dal trattamento che derivano in particolare da:

- **distruzione,**
- **perdita,**
- **modifica,**
- **divulgazione non autorizzata o**
- **accesso,** in modo **accidentale o illegale,**
- a dati personali trattati.

L'adesione a un **codice di condotta approvato** o a un **meccanismo di certificazione approvato** può essere utilizzata come elemento per dimostrare la conformità alla normativa.

Esempi di misure di sicurezza

- **Pseudonimizzazione e cifratura** dei dati personali
- Capacità di **assicurare** su base permanente la **riservatezza**, **l'integrità**, la **disponibilità** e la **resilienza** dei **sistemi** e dei **servizi di trattamento**
- Capacità di **ripristinare tempestivamente** la **disponibilità** e **l'accesso dei dati personali** in caso di **incidente fisico o tecnico**
- **Procedura** per **testare, verificare e valutare regolarmente** l'**efficacia** delle **misure tecniche e organizzative** al fine di **garantire la sicurezza** del trattamento

Notifica violazione dei dati

- In caso di violazione dei dati personali, il **titolare** deve notificare la violazione al **Garante privacy** senza ingiustificato ritardo e, ove possibile, entro **72 ore** dal momento in cui ne è venuto a conoscenza, a meno che sia improbabile che la violazione dei dati personali presenti un rischio per i diritti e le libertà delle persone fisiche.
- Qualora la notifica all'autorità di controllo non sia effettuata entro 72 ore, è corredata dei motivi del ritardo.
- Il **responsabile** del trattamento deve **informare il titolare** del trattamento **senza ingiustificato ritardo** dopo essere venuto a conoscenza della violazione.

Comunicazione violazione dei dati

Quando la **violazione** dei dati personali **può** presentare un **rischio elevato per i diritti e le libertà delle persone fisiche**, il **titolare** del trattamento deve **comunicare** la **violazione** all'**interessato** senza ingiustificato ritardo.

A meno che non sia soddisfatta una delle seguenti condizioni:

- il titolare ha attuato **misure** di protezione **tecniche e organizzative adeguate** e tali misure erano state applicate ai dati oggetto della violazione (es. **cifratura**);
- il titolare ha **successivamente adottato misure** atte a **scongiurare** il sopraggiungere di un **rischio** elevato;
- la **comunicazione** richiederebbe **sforzi sproporzionati**. In tal caso, si deve procedere a una **comunicazione pubblica** o a una misura simile, tramite la quale gli interessati sono informati con analoga efficacia.

Valutazione d'impatto sulla protezione dei dati (DPIA – *Data Protection Impact Assessment*)

Quando un tipo di trattamento, allorché prevede in particolare l'uso di **nuove tecnologie**, considerati

- la **natura**,
- l'**oggetto**,
- il **contesto** e
- le **finalità** del trattamento,

può presentare un **rischio elevato** per i diritti e le libertà delle persone fisiche,

il **titolare** del trattamento deve effettuare, **prima** di procedere al trattamento, una **valutazione dell'impatto dei trattamenti previsti sulla protezione dei dati personali**.

Una **singola valutazione** può esaminare un **insieme di trattamenti simili** che presentano **rischi elevati analoghi**.

Quando occorre la valutazione d'impatto?

E' richiesta in particolare nei casi seguenti:

- **valutazione sistematica** e globale di **aspetti personali** relativi a persone fisiche, basata su un trattamento automatizzato, compresa la **profilazione**, e sulla quale si fondano **decisioni** che hanno **effetti giuridici** o incidono in modo analogo significativamente su dette persone fisiche
- il trattamento, su larga scala, di **categorie particolari di dati personali** o di dati relativi a condanne penali e a reati
- la **sorveglianza sistematica** su larga scala di una **zona** accessibile al **pubblico**.

Contenuto della valutazione d'impatto

- **descrizione** sistematica dei trattamenti previsti e delle finalità del trattamento
- valutazione della **necessità e proporzionalità** dei **trattamenti** in relazione alle **finalità**
- valutazione dei **rischi** per i diritti e le libertà degli interessati
- **misure** previste **per affrontare i rischi**, includendo
 - le garanzie,
 - le misure di sicurezza
 - i meccanismi per garantire la protezione dei dati personali e dimostrare la conformità al regolamento, tenuto conto dei diritti e degli interessi legittimi degli interessati e delle altre persone in questione.

Responsabile della protezione dei dati

Comunemente detto **DPO (Data Protection Officer)**

Svolge numerosi compiti di **supporto all'applicazione** del **Regolamento**

Deve essere persona **esperta** sulla **normativa** e **prassi** della **protezione dei dati**

Può essere un **dipendente** del Titolare o del Responsabile del trattamento o un **soggetto esterno** con cui si stipula un contratto di servizi

Non deve essere in **conflitto di interesse**

Non deve ricevere **istruzioni** dal Titolare o dal Responsabile del trattamento

I suoi **dati** devono essere **pubblicati** e **comunicati al Garante**

Quando deve essere nominato il DPO?

- il trattamento è effettuato da un'**autorità pubblica** o da un organismo pubblico, eccettuate le autorità giurisdizionali o
- le **attività principali** del titolare del trattamento o del responsabile del trattamento consistono in **trattamenti** che, per loro natura, ambito di applicazione e/o finalità, richiedono il **monitoraggio regolare e sistematico degli interessati su larga scala** o
- le **attività principali** del titolare del trattamento o del responsabile del trattamento consistono nel **trattamento**, su **larga scala**, di **categorie particolari di dati personali** di cui all'articolo 9 o di dati relativi a condanne penali e a reati.

Un gruppo imprenditoriale può nominare un unico DPO, a condizione che sia facilmente raggiungibile da ciascuno stabilimento.

Compiti minimi del DPO 1/2

- **Informare** e fornire **consulenza** al **titolare** o al **responsabile** e ai **dipendenti** che eseguono il trattamento sugli **obblighi** del regolamento e di altre norme EU o nazionali sulla protezione dei dati
- **Sorvegliare l'osservanza**
 - del **Regolamento**,
 - di altre **norme** EU o nazionali sulla protezione dei dati
 - delle **politiche** del titolare o del responsabile sulla protezione dei dati personali, compresi l'attribuzione delle responsabilità, la sensibilizzazione e la formazione del personale che partecipa ai trattamenti e alle connesse attività di controllo
- fornire, se richiesto, un **parere** in merito alla **valutazione d'impatto** sulla protezione dei dati e **sorvegliarne** lo svolgimento

Compiti minimi del DPO 2/2

- **cooperare** con l'autorità di controllo (**Garante privacy**)
- fungere da **punto di contatto** per l'**autorità di controllo** per questioni connesse al trattamento, tra cui la consultazione preventiva ed effettuare, se del caso, consultazioni relativamente a qualunque altra questione.

Nell'eseguire i propri compiti il responsabile della protezione dei dati **considera** debitamente i **rischi** inerenti al trattamento, tenuto conto

- della **natura**,
- dell'**ambito di applicazione**,
- del **contesto** e
- delle **finalità** del trattamento.

Codici di condotta

L'elaborazione di codici di condotta può contribuire alla **corretta applicazione** del **regolamento**, in funzione delle **specificità** dei vari **settori** di trattamento e delle **esigenze** specifiche delle **micro, piccole e medie imprese**.

Le **associazioni** e gli altri **organismi rappresentanti le categorie di titolari** del trattamento o **responsabili** del trattamento possono elaborare i codici di condotta, modificarli o prorogarli, allo scopo di precisare l'applicazione del regolamento.

Codici di condotta Garante privacy

Esempi:

- *trattamento dati in materia di informazioni commerciali*
- *sistemi informativi crediti al consumo affidabilità pagamenti*
- *trattamento dati sanitari per didattica e pubblicazioni*

Certificazioni

Il Regolamento incoraggia l'istituzione di **meccanismi di certificazione** della protezione dei dati nonché di **sigilli e marchi di protezione dei dati** allo scopo di **dimostrare** la **conformità** al regolamento dei trattamenti effettuati dai titolari e dai responsabili del trattamento.

Devono essere tenute in considerazione le esigenze specifiche delle micro, piccole e medie imprese.

Lettura: [pagina delle certificazioni Accredia](#)

Trasferimenti di dati extra UE 1/3

Principio generale

Può avvenire soltanto se il titolare e il responsabile del trattamento rispettano le condizioni del Regolamento.

Le regole per il trasferimento di dati personali extra UE sono applicate al fine di assicurare che il livello di protezione delle persone fisiche garantito dal regolamento non sia pregiudicato.

CONDIZIONI:

- **decisione di adeguatezza** (la Commissione Europea stabilisce che determinati Paesi garantiscano un livello di protezione adeguato), non occorrono autorizzazioni specifiche
- **garanzie adeguate** (manca una decisione di adeguatezza ma il titolare o il responsabile del trattamento forniscono garanzie adeguate), es. **norme vincolanti d'impresa** (norme giuridicamente vincolanti adottate a livello di gruppo di impresa), **clausole contrattuali tipo** adottate dalla Commissione o da un'autorità di controllo

Trasferimenti di dati extra UE 2/3

Deroghe

In mancanza delle condizioni precedenti, il trasferimento può essere effettuato alle seguenti condizioni:

- **consenso dell'interessato**, dopo essere stato informato dei possibili rischi dei trasferimenti, dovuti alla mancanza di una decisione di adeguatezza e di garanzie adeguate
- **trasferimento necessario all'esecuzione di un contratto** concluso tra l'**interessato** e il **titolare** del trattamento o all'esecuzione di misure precontrattuali adottate su istanza dell'interessato
- **trasferimento necessario per la conclusione o l'esecuzione di un contratto** stipulato tra il **titolare** del trattamento e un'altra persona fisica o giuridica
- **trasferimento necessario per importanti motivi di interesse pubblico**

Trasferimenti di dati extra UE 3/3

Deroghe

- trasferimento **necessario** per accertare, esercitare o difendere un **diritto** in **sede giudiziaria**;
- trasferimento **necessario** per **tutelare gli interessi vitali** dell'**interessato** o di **altre persone**, qualora l'interessato si trovi nell'incapacità fisica o giuridica di prestare il proprio consenso;
- trasferimento effettuato a partire **da un registro pubblico**.
(registro che, a norma del diritto dell'Unione o degli Stati membri, mira a fornire informazioni al pubblico e può essere consultato tanto dal pubblico in generale quanto da chiunque sia in grado di dimostrare un legittimo interesse, solo a condizione che sussistano i requisiti per la consultazione previsti dal diritto dell'Unione o degli Stati membri).

Trasferimenti di dati UE-USA 1/2

Nel tempo le condizioni di liceità dei trasferimenti di dati personali verso gli USA in ambito commerciale hanno sperimentato alterne vicende.

Safe Harbor – invalidato nel 2015 da sentenza della Corte di Giustizia Europea (c.d. "Schrems I")

Privacy Shield - invalidato nel 2020 da sentenza della Corte di Giustizia Europea (c.d. "Schrems II")

*Vi segnalo il sito web **NOYB** (My Privacy is None of Your Business), associazione no profit fondata dall'attivista austriaco Maximilian Schrems.*

Trasferimenti di dati UE-USA 2/2

ATTUALMENTE: **Data Privacy Framework**

Il 10 luglio 2023 la Commissione europea ha adottato la decisione di adeguatezza del quadro normativo sulla privacy dei dati UE-USA. Sulla base della decisione di adeguatezza, i dati personali possono circolare liberamente dall'UE alle società negli Stati Uniti che partecipano al Data Privacy Framework.

Maggiori informazioni sul [portale della Commissione Europea](#).

Sanzioni GDPR

Alcune sanzioni sono previste dal Regolamento.

Gli Stati Membri possono stabilire ulteriori sanzioni.

Per alcune violazioni (es. obblighi del titolare o del responsabile del trattamento), sono previste sanzioni amministrative pecuniarie **fino a 10 000 000 EUR**, o per le imprese, **fino al 2 % del fatturato mondiale totale annuo** dell'esercizio precedente, se **superiore**.

Per altre violazioni (es. principi di base, diritti degli interessati, trasferimenti extra UE) sono previste sanzioni amministrative pecuniarie fino a **fino a 20 000 000 EUR**, o per le **imprese**, **fino al 4 % del fatturato mondiale totale annuo** dell'esercizio precedente, **se superiore**.

Sanzioni Codice Privacy

Gli Stati Membri possono stabilire ulteriori sanzioni.

Illeciti penali nel Codice Privacy:

Trattamento illecito di dati (art. 167)

Comunicazione e diffusione illecita di dati personali oggetto di trattamento su larga scala (art. 167-bis)

Acquisizione fraudolenta di dati personali oggetto di trattamento su larga scala (art. 167-ter)

Falsità nelle dichiarazioni al Garante e interruzione dell'esecuzione dei compiti o dell'esercizio dei poteri del Garante (art. 168)

Pene accessorie: pubblicazione della sentenza sul sito internet del Ministero della Giustizia (art. 172 e art. 36 codice penale, c. 2,3)

Attenzione!!

Il Regolamento non è l'unica fonte a cui attenersi per il rispetto delle regole su privacy e protezione dei dati personali.

Si deve rispettare anche il Codice Privacy aggiornato e ogni altra normativa pertinente (es. Statuto dei lavoratori).

Occorre tenere conto di altri importanti documenti a supporto dell'applicazione concreta, es.

- Linee Guida Comitato Europeo per la Protezione dei Dati
(IMPORTANTI)
- Provvedimenti del Garante italiano e dei Garanti nazionali di altri paesi europei (IMPORTANTI)

Il Garante

Autorità amministrativa indipendente

Il Garante per la protezione dei dati personali è un organo collegiale, composto da quattro membri eletti dal Parlamento (2 dalla Camera, 2 dal Senato).

Il Collegio rimane in carica per un mandato di sette anni non rinnovabile.

Compiti del Garante - sintesi

- Verifica l'applicazione della normativa privacy
- Esamina i reclami e le segnalazioni e decide sui ricorsi
- Può vietare il trattamento illecito dei dati e disporre il blocco
- Segnala a Governo e Parlamento l'opportunità di interventi normativi
- Partecipa alla discussione su iniziative normative con audizioni in Parlamento
- Esprime pareri
- Denuncia fatti perseguibili d'ufficio
- Predisporre una relazione annuale

Link utili

Garante per la protezione dei dati personali (Garante privacy)

European Data Protection Board – Linee Guida, raccomandazioni e migliori prassi

Testo del Regolamento

Testo del Codice privacy

Guida all'applicazione del GDPR

Attenzione ripasso!!!

Cose da sapere di questa lezione:

- ambito di applicazione
- definizioni dei concetti
- soggetti coinvolti nel trattamento
- liceità del trattamento
- informativa
- consenso
- trattamento delle categorie particolari di dati
- diritti dell'interessato
- obblighi del titolare e del responsabile del trattamento
- data protection by design e by default
- registri delle attività
- sicurezza
- violazione dei dati
- valutazione di impatto
- trasferimenti extra UE
- DPO
- Sanzioni